

Windows Server Administration

Formateur : **Michaelis Mahouto**

Cloud · DevOps · Administration Systèmes | m.mahouto@cfa-insta.fr

Session Paris — 7 jours de formation intensive

Votre Formateur

Michaelis Mahouto

MM

Cloud · DevOps · Windows Linux
SRE / Infrastructure

m.mahouto@cfa-insta.fr

Objectifs du cours

- Administrer un environnement Active Directory : identités, accès, utilisateurs, groupes et ressources
- Déployer une infrastructure Active Directory sécurisée (domaines, OU, contrôleurs de domaine, GPO)
- Comprendre l'architecture et automatiser l'administration (forêt, réplication, PowerShell, troubleshooting)

Méthode pédagogique

AM

Cours +
Démonstrations

PM

TP guidés +
Mini évaluations



Supports,
commandes, checklist

Tour de Table

Faisons connaissance !



Nom & Prénom



Parcours professionnel



Métier actuel



Pourquoi l'informatique ?



Futur métier visé



Ce que vous voulez apprendre

Règles de Fonctionnement

Ponctualité, discipline et sécurité



Horaires

09:00 – 17:00
Pause : 10:30–10:45 ; 15:30-15:45
Déjeuner : 12:00–13:30



Ponctualité

Présence avant 09:00
Retard/absence à signaler
Cours et TP obligatoires



Discipline

Téléphone en silencieux
Écoute et respect mutuel
Pas de discussions parallèles



Sécurité & TP

Ne jamais partager les accès
Nettoyer les ressources Azure
Sauvegarder captures et notes

Administration à distance

DNS & Active Directory

FSMO & Réplication

Sécurité & GPO

AD CS & AD FS

Administration & Sécurité

Windows Server — Cours Complet

Plan du cours

01

Administration à distance

RDP · WinRM · PowerShell

02

DNS & Infrastructure

Zones · Split Brain · Zone Policy

03

Active Directory Core

FSMO · Base NTDS · SYSVOL · RODC

04

Sécurité & Groupes

AdminCount · Protected Users · GPO

05

AD CS — Certificats

PKI · Autorités · Enrôlement

06

AD FS — Fédération

SSO · SAML · OAuth

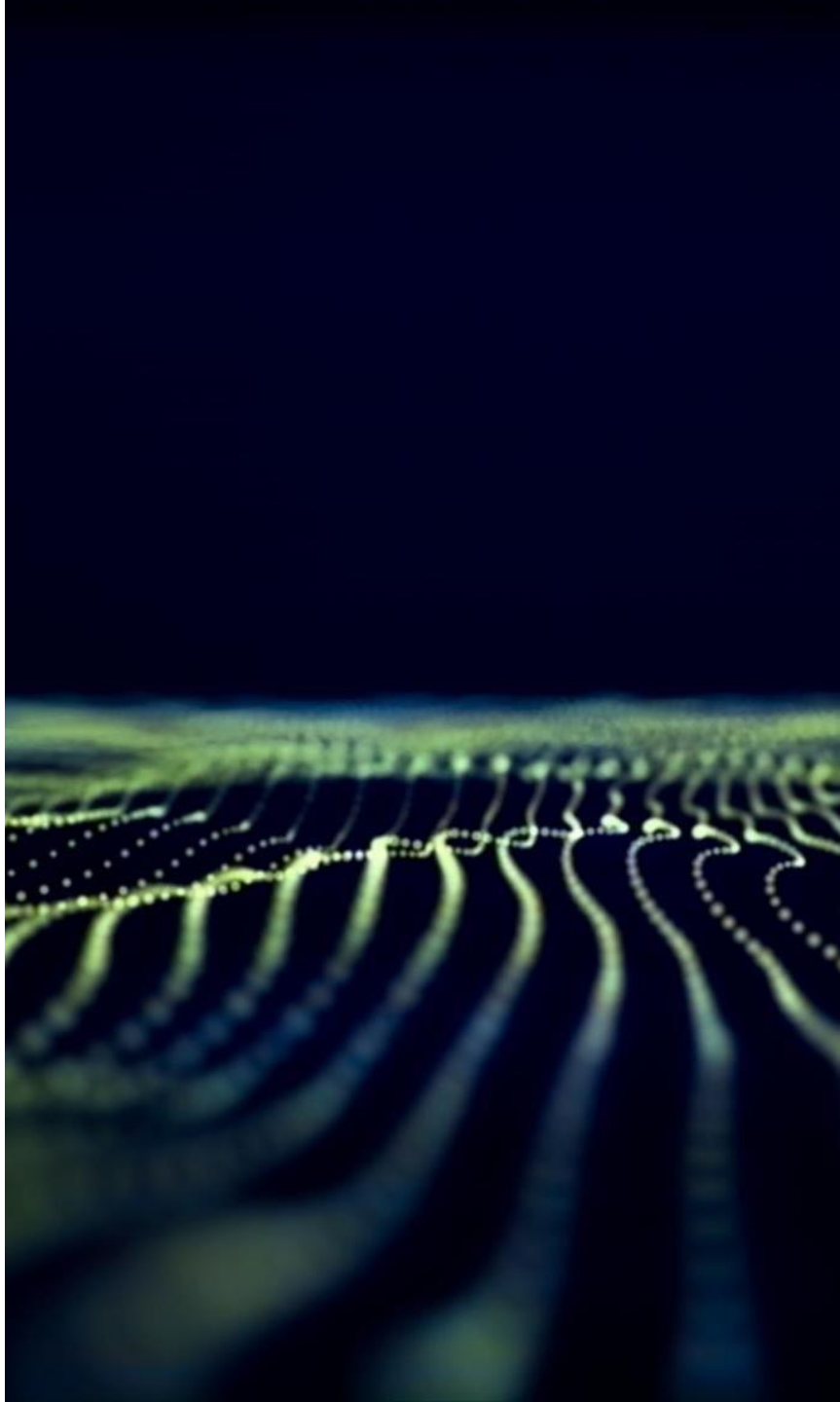
Administrer un serveur à distance

Protocoles historiques :

- RPC (port 135)
- RDP (port 3389)

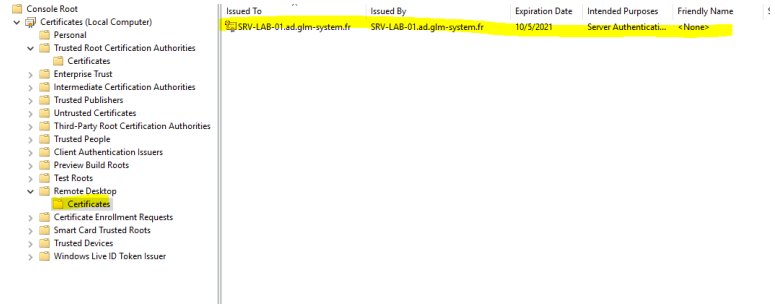
Evolution suivantes

- WinRM
  - Port 5985 non sécurisé
  - Port 5986 sécurisé



Administrer un serveur à distance

- Rappel du protocole RDP
  - Le protocole RDP (Remote Desktop Protocole) permet de déporter le bureau à travers le réseau
  - Est chiffré par certificat *(stocké dans le store computer > Remote Desktop > Certificate)*



Administrer un serveur à distance

- A propos du WinRM
  - Protocole appelé lors de l'usage de PowerShell entre deux machines
  - Basé sur le protocole HTTP (réalise des call SOAP), chiffrés par Kerberos
  - Le service WinRM repose sur deux protocole
    - RPC et HTTP
  - Cas d'usage : pilotage de machines Windows depuis un environnement Linux *(Ansible, call winRM applicatif…)*
    - 2 méthodes
      - Autorisation des communications non-chiffrées entre Windows et Linux (Allow Unencrypted)
      - Configuration par certificat TLS

LAB 1 Configuration de winRM - Serveur

- Connectez-vous à votre machine virtuelle, et lancez une commande PowerShell
- Exécutez la commande suivante : **winrm quickconfig**
  - Cette commande permet l'initialisation du service winRM
- Exécutez la commande : **winrm get winrm/config, puis winrm get winrm/config/service**
  - Comparez le résultat des deux lignes de commandes, et déduisez la commande permettant d'obtenir la configuration cliente
- Pour connaître les groupes ayant la permission de réaliser des appels Powershell distant, éxécutez la ligne de commande suivante : **Get-PSSessionConfiguration | Select Name, Permission**



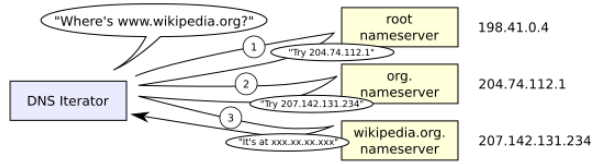
Les différents rôles Microsoft

Premier composant de l’infrastructure : le serveur DNS

Généralité sur le serveur DNS

- Le service de résolution de nom de domaine (DNS) permet de réaliser une traduction de nom de machines, de services vers une IP

- Notions fondamentales :
  - TLD : Top Level Domain – Domaines du plus haut niveau (FR, COM, TV…)
  - Redirecteurs : configuration permettant à un serveur DNS d'interroger un autre serveur DNS
  - Résolution récursive : résolution à l'aide de serveurs connus dans une liste préconfigurée
    - Comportement commun : si A n'est pas disponible, interrogation du serveur B
  - Résolution itérative : résolution de l'aborescence du domaine
    - Exemple : qui porte .com? Qui porte google.com? Qui porte requesthelper.google.com?
  - Split brain : notion quand une configuration nécessite des enregistrements locaux et distants



Généralité sur le serveur DNS

- Le transfert de zone est la technique de réplication DNS hors Active Directory (ou permet également le transfert d'enregistrements d'un serveur Windows vers un serveur Linux)

- La validité d'un enregistrement DNS est lié à deux paramètres : le TTL (Time To Live) de l'enregistrement, qui donne une première expiration de l'enregistrement, ainsi que le nettoyage du cache DNS du serveur

- Sous Windows Server, le service DNS est un des composants cœur du fonctionnement de Microsoft Active Directory. Des disfonctionnements sur ce service sont souvent à l'origine de problématiques de synchronisation entre les contrôleurs de domaine.

Installation du rôle et création de votre première zone

- Installez le service DNS à l'aide de la ligne de commande powershell suivante :
  Add-WindowsFeature DNS *-IncludeManagementTools*
  - Le paramètre –includeManagementTools permet d'inclure la console de gestion DNS dans le déploiement

- Créez votre zone de recherche directe via la ligne Powershell suivante :
  - Add-DnsServerPrimaryZone -Name "ad.FQDN.local" -ZoneFile "ad.FQDN.local.dns"

- Vous ne disposez pas encore d'un domaine Active Directory, vous pouvez par conséquent retrouver votre fichier de zone dans le répertoire suivant : **C:\Windows\System32\dns**

- Ajoutez un redirecteur conditionnel afin de permettre la résolution d'enregistrements DNS

Nouveauté à partir de Windows Server 2016

- Windows Server 2016 implémente la notion de « *zone policy* » : selon le réseau ou de l'interface de répondre une réponse différente
  - Elle permet de :
    - Rediriger la requête selon le serveur DNS d'interrogation (à l'aide transfert de zone)
    - De répondre en fonction de l'heure de la journée
    - Répondre différemment selon l'interface d'entrée (publique/privée)

Exemple d’implémentation

- Sur votre serveur DNS, ajoutez une interface « publique » avec une nouvelle adresse IP qui sera notée ici IPB.
  L’adresse IP initiale de votre serveur sera notée IPA.
  Votre nom de domaine sera noté FQDN.LOCAL

- Depuis l’ISE, ajoutez le code suivant :

```
Add-DnsServerZoneScope -ZoneName "FQDN.LOCAL" -Name "LocalScope"
Add-DnsServerZoneScope -ZoneName "FQDN.LOCAL" -Name "PublicScope"
Add-DnsServerQueryResolutionPolicy -Name "PublicPolicy"  -ServerInterface "eq,IPB" -ZoneScope "PublicScope"  -ZoneName "FQDN.LOCAL" -PassThru
Add-DnsServerQueryResolutionPolicy -Name "LocalPolicy"  -ServerInterface "eq,IPA" -ZoneScope "LocalScope"  -ZoneName "FQDN.LOCAL" -PassThru
Add-DnsServerResourceRecord -ZoneName "FQDN.LOCAL" -A -Name "www" -IPv4Address "192.168.1.100" -ZoneScope "LocalScope"
Add-DnsServerResourceRecord -ZoneName "FQDN.LOCAL" -A -Name "www" -IPv4Address "10.0.5.8" -ZoneScope "PublicScope"
```

- Depuis votre serveur, réalisez un NSLOOKUP sur l’interface publique, puis la privée

  nslookup
  server IPA
  www.FQDN.local
  server IPB
  www.FQDN.local

Le résultat doit être différent

Technique « Ancienne » de gestion de split Brain sans duplication de zone

- Réalisez un nslookup sur l'entrée ns1.google.com et sur ns2.google.fr
- Créez une zone DNS appelée ns1.google.com, ayant un enregistrement A à la racine avec pour valeur « 10.2.2.2 »
- Réalisez un nslookup sur l'entrée ns1.google.com, puis sur ns2.google.com, puis sur google.com
  - Que notez-vous?

Les différents rôles Microsoft

Composant consommant le service DNS : Active Directory

Les rôles FSMO *(Flexible Single Master Operation)*

- **Maître de schéma**
  - **Unique dans la forêt (généralement sur le domaine racine).** Seul serveur a pouvoir réaliser des modifications sur le schéma Active Directory.

- **Maître de dénomination de domaine**
  - **Unique dans la forêt (généralement sur le domaine racine).** Permet l'ajout ou la suppression de domaine, ainsi que la suppression de la partition d'application

- **Maître RID**
  - Permet l'attribution de pool RID aux contrôleurs de domaine (qui seront utilisés lors de la génération de SID aux objets). Un SID est composé du SID domaine + d'un RID.
  - Par défaut, le maître RID attribut des pools de 500. Les contrôleurs de domaines rafraichissent leurs pools une fois arrivé a ux 100 derniers.
  - En cas de panne du serveur RID, les SID seront distribués par les Contrôleurs de domaines jusqu'à épuisement du Pool.

- **Maître d'infrastructure**
  - Le maître d'infrastructure assure la mise à jour des références entre les objets de différents domaines

- **Maître émulateur PDC**
  - Permet la gestion de la mise à jour des stratégies de groupe dans un domaine. Il gère aussi la synchronisation des horloges.
  - En cas de différence de plus de 5 minutes entre un contrôleur de domaine et un client engendre une impossibilité d'ouverture de session.

La base de données

- La base de données est découpée logiquement en plusieurs partitions
  - La partition de **configuration** contient la structure logique de la forêt *(contient les sites AD, les sous-réseaux…)*
    - *Réplication sur les DCs de la forêt*
  - La partition **domaine** contient les objets créées dans le domaine : utilisateurs, GPC *(Group Policy Containers)*
    - *Réplication sur les DCs du domaine*
  - La partition **schéma** contient la définition des objets (et donc par conséquent les objets pouvant être créés)
    - *Sur tous les DCs de la forêt*
  - La partition **Application** contient des objets de tous types sauf de sécurité (utilisateurs, groupes, ordinateurs)
    - *Sur tous les DCs de la forêt (configurable)*
    - *Les zones DNS intégrées dans l'AD sont dans cette partition*

La base de données

- La base de données est stockée dans le fichier NTDS (par défaut dans **C:\Windows\System32\ntds.dit**)

- Les modifications sont enregistrées dans des fichiers EDB*.log, utilisés pour les transactions en attendant validation

- La validation ajoute une entrée dans le fichier EDB.CHK

- **Bonne pratique**
  - Il est fortement recommandé d'exclure ces fichiers dans les scans antivirus

LAB 1 – Configuration de votre premier domaine

- A l'aide de PowerShell, installez le service ADDC
  - Install-WindowsFeature AD-Domain-Services –IncludeManagementTools
- Déployez votre forêt Active Directory
  - Install-ADDSForest -DomainName "ad.FQDN.LOCAL" –InstallDns
  - Des alertes de vérifications peuvent apparaître si votre carte réseau est en DHCP

LAB 2 – Réaliser une sauvegarde AD à l'aide d'un compte sécurisé

- Dans votre domaine Active Directory, générez un compte svc_backupad
  - Ajoutez le dans le groupe **BUILTIN\Backup Operator** et **Protected Users**

- A l'aide de PowerShell, installez la fonctionnalité Wbackup (Windows Backup)
  - *Install-WindowsFeature -Name Windows-Server-Backup -IncludeManagementTools*

- Ajoutez un disque supplémentaire à votre VM (de 20 Go), formattez le disque et mapper le avec la lettre D:

- Vérifiez avec votre compte administrateur l'état de la dernière sauvegarde AD
  - Repadmin /showbackup

- Lancez Powershell en tant que compte svc_backupad, puis exécutez la commande suivante, avec le compte svc_backupad avec une console powershell à privilège:
  - ```
    $WBpolicy = New-WBPolicy
    Add-WBSystemState -Policy $Wbpolicy
    $WBtarget = New-WBBackupTarget -VolumePath "C:«
    Add-WBBackupTarget -Policy $wbpolicy -Target $Wbtarget
    Start-WBBackup -Policy $WBpolicy
    ```
    ```

LAB2 - Explication

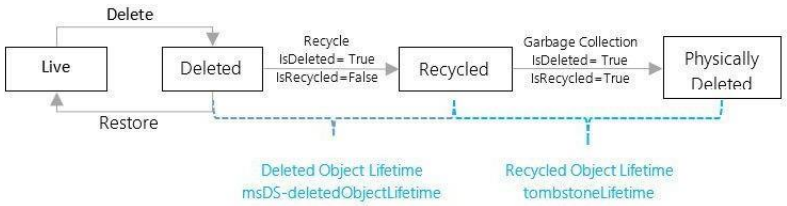
- Durant le LAB 2, vous avez autorisé le compte svc_backupad à pouvoir réaliser des opérations de sauvegardes sur l'Active Directory, sans pour autant lui déléguer de droits « applicatifs »

- Le positionnement dans le groupe protected users renforce la sécurité du compte (pas de cache NTLM, pas de trace en local sur le hash du mot de passe)

- L'application de cette politique permet de mettre en œuvre la politique du « *least privilege »* : on ne donne au compte que les permissions dont il a besoin
  - *Cette politique est une des nombreuses recommandation de l'ANSII en terme d'exploitation et de gestion de sécurité*

La corbeille dans l'Active Directory

- Active Directory dispose d'une fonctionnalité de Corbeille (depuis AD 2008 R2)
  - L'activation du paramètre est définitif



AVANT	APRES
L'objet est placé dans un état "tombstone" (180 jours sous Windows Server 2003 SP1 et supérieur), 60 jours pour les versions précédentes. La plupart des liens sont supprimés (appurtenance à un groupe, permission…)	L'objet entre dans un état "logically deleted" pour une période de 180 jours par défaut (définie par msDS-DeletedObjectLifetime) . La plupart des attributs sont conservés par le système.
L'attribute "IsDeleted" est changé à TRUE.	Attribute "IsDeleted" is changed to TRUE value.
	Value of "WhenDeleted" is changed to "Time Changed".
	A unique value is assigned to Windows security descriptor.
	RDN is changed to an impossible value.
L'objet est déplacé dans le conteneur "Deleted Objects" (CN=Deleted Objects).	The object is moved to "Deleted Objects" container (CN=Deleted Objects).
Un processus "Garbage collector" (ramasse miette) supprime les objets dont la période "thumbstone" a expiré. L'objet est complètement supprimé et ne peut plus être restauré.	L'objet passe en état "Recycle", sur la période définie par tombstoneLifetime. La plupart des attributs sont effaces.
	Un processus "Garbage collector" (ramasse miette) supprime les objets dont la période "thumbstone" a expiré. L'objet est complètement supprimé et ne peut plus être restauré. L'objet est complètement supprimé et ne peut plus être restauré.
Pour réaliser une restauration, l'administrateur doit réaliser une restauration en mode recovery (F8 au démarrage)	L'objet est restaurable en PowerShell ou via un panneau de contrôle dans AD.

La corbeille de l’Active Directory

- Par défaut, la valeur de msDS-DeletedObjectLifetime (valeur par défaut : null, dans ce cas de figure, msDS-DeletedObjectLifetime = tombstoneLifetime)

- Par défaut, la valeur de tombstoneLifetime est de 180 jours

LAB 3 – Corbeille de l’Active Directory

- Exécutez la ligne de commande suivante afin d’activer la corbeille Active Directory
  - Enable-ADOptionalFeature -Identity ' CN=Recycle Bin Feature,CN=Optional Features,CN=Directory Service,CN=Windows NT,CN=Services,CN=Configuration, DC=XXX,DC=XXX ' -Scope ForestOrConfigurationSet -Target 'XX.XXX'
- Supprimez le compte **svc_backupad**

- Restaurez le compte svc_backupad via la ligne de commande suivante afin de restaurer votre compte Active Directory
  - Get-ADObject -Filter 'name -like "svc_backupad*"' -IncludeDeletedObjects | Restore-ADObject -TargetPath 'CN=Users,DC=XXX,DC=XXX'

- Contrôlez l’état de votre compte Active Directory et ses attributions de groupe

Le dossier SYSVOL

- Le dossier SYSVOL est un répertoire synchronisé entre les différents serveurs Windows par l'intermédiaire du service DFSR (Distributed File System Replication – depuis Windows Server 2012 R2)
  - DFSR est une évolution de FSR, là ou FSR devait synchroniser l'ensemble des fichiers à mettre à jour, DFSR est capable de mettre à jour les fichiers

- Le répertoire SYSVOL est un répertoire qui contient les éléments suivants:
  - Les modèles de stratégies de groupe et les stratégies de groupes
  - Les scripts de session

Les RODC

- Les serveurs RODC sont des contrôleurs de domaine en lecture seule
  - Il n'est pas possible de réaliser la mise depuis un RODC. Cependant, ce dernier à la capacité de transférer la demande d'authentification auprès d'un autre contrôleur de domaine.
- Il n'y a qu'un seul RODC par site Active Directory
- Il est possible d'ajouter le rôle DNS sur un serveur AD, mais comme pour l'AD, les zones intégrées à l'AD seront en lecture seule
- A la création d'un RODC, 2 groupes sont générés
  - Un groupe dont la mise en cache de mot de passe est autorisé
  - Un groupe dans la mise en cache de mot de passe est refusé
    - Recommandé : créer un groupe de sécurité globale, mettre les utilisateurs à privilèges dans ce groupe
- Intérêt du RODC : « *Le RODC est une alternative de sécurité afin de gérer des sites distants faiblement sécurisés. Le RODC ne peut valider les mots de passe que d'un certain nombre de comptes. Ces comptes sont identifiables, il est donc possible de modifier les mots en passe de ces utilisateurs en cas de corruption* »

Active Directory et les restaurations

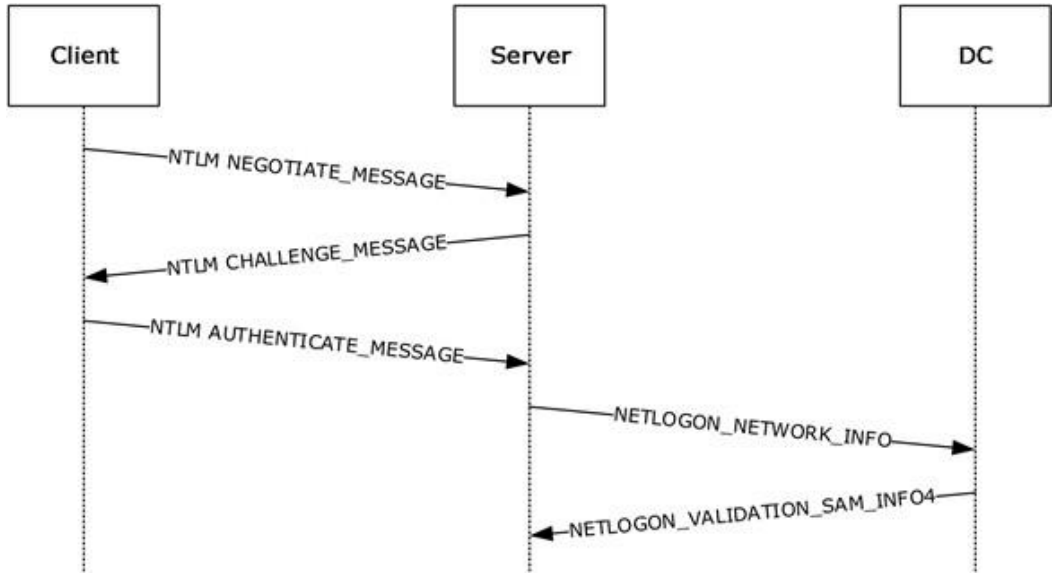
- Il existe deux types de restauration :
  - Restauration AD autoritaire : on restaure le contrôleur de domaine à la dernière version, puis on marque les objets à restaurer. Au redémarrage suivant, ce dernier provoque une synchronisation vers les autres contrôleurs de domaine *(celui-ci ayant un plus grand numéro de version)*
    - Cas d'usage : restaurer des objets supprimés
  - Restauration AD ne faisant pas autorité (restauration normale, par défaut) : on restaure le contrôleur de domaine a une date ultérieure. Au démarrage, ce dernier réalise une mise à jour de sa base de données avec les autres serveurs.
    - Cas d'usage : le contrôleur de domaine ne démarre plus après une mise à jour

Active Directory et les restaurations

- Il existe deux types de restauration :
  - Restauration AD autoritaire : on restaure le contrôleur de domaine à la dernière version, puis on marque les objets à restaurer. Au redémarrage suivant, ce dernier provoque une synchronisation vers les autres contrôleurs de domaine *(celui-ci ayant un plus grand numéro de version)*
    - Cas d'usage : restaurer des objets supprimés
  - Restauration AD ne faisant pas autorité (restauration normale, par défaut) : on restaure le contrôleur de domaine a une date ultérieure. Au démarrage, ce dernier réalise une mise à jour de sa base de données avec les autres serveurs.
    - Cas d'usage : le contrôleur de domaine ne démarre plus après une mise à jour

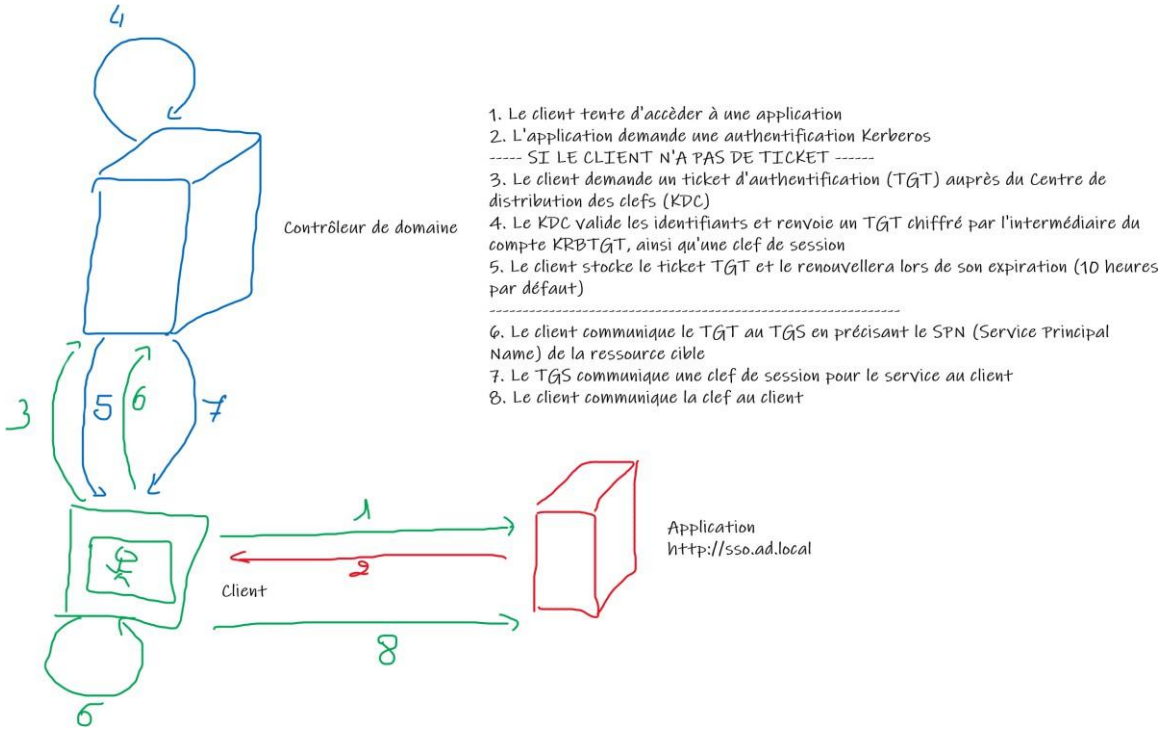
Les principes d'authentification

- **Nous pouvons identifier plusieurs types d'authentification**
  - **NTLM :** un hash est communiqué auprès d'un serveur d'authentification, qui communique les identifiants à un contrôleur de domaine



Les principes d’authentification

- **Nous pouvons identifier plusieurs types d’authentification**
  - **Kerberos**



Les groupes Active Directory

- **Il existe plusieurs types de groupes Active Directory :**
  - **Sécurité : est réservé aux configurations de sécurités (délégation, autorisation…)**
  - **Distribution : est réservé aux listes de distribution et de diffusion**

- **Les groupes de sécurités disposent de plusieurs portées :**
  - **Globale (portée par défaut des groupes Active Directory)**
  - **Locale**
  - **Universelle**

Les groupes Active Directory

- **Groupes globaux** : Les membres doivent provenir du même domaine. Ils peuvent être utilisés pour accorder des permissions à travers les domaines ou les forêts. Ces groupes sont utiles pour rassembler des utilisateurs ou des groupes ayant des fonctions similaires.

- **Groupes universels** : Ils peuvent contenir des membres de différents domaines **dans la même forêt.** Les groupes universels sont utilisés pour les permissions qui traversent plusieurs domaines, permettant ainsi une gestion plus flexible des ressources.

- **Groupes locaux de domaine** : Ils sont principalement utilisés pour donner des permissions sur des ressources locales, comme des serveurs ou des applications. Les membres peuvent provenir de n'importe quel domaine de la forêt, mais les permissions sont limitées au domaine où le groupe a été créé.

Les groupes Active Directory

Étendue	Membres possibles	Conversion d'étendue	Peut accorder des autorisations	Membre possible de
Universel	Comptes de n'importe quel domaine dans la même forêt. Groupes globaux de n'importe quel domaine dans la même forêt Autres groupes universels de n'importe quel domaine de la même forêt	Peut être converti en Étendue du domaine local si le groupe n'est membre d'aucun autre groupe universel Peut être converti en étendue globale si le groupe ne contient aucun autre groupe universel	Sur n'importe quel domaine de la même forêt ou de forêts approuvées	Autres groupes universels dans la même forêt Groupes locaux dans la même forêt ou forêts de confiance Groupes locaux sur des ordinateurs dans la même forêt ou des forêts d'approbation
Globale	Comptes du même domaine Autres groupes globaux du même domaine	Peut être converti en portée universelle si le groupe n'est membre d'aucun autre groupe global	Sur n'importe quel domaine de la même forêt, ou approuvant des domaines ou des forêts	Groupes universels de n'importe quel domaine de la même forêt Autres groupes globaux du même domaine Groupes locaux de n'importe quel domaine de la même forêt ou de n'importe quel domaine d'approbation
Domaine local	Comptes de n'importe quel domaine ou domaine de confiance Groupes globaux de n'importe quel domaine ou domaine de confiance Groupes universels de n'importe quel domaine de la même forêt Autres groupes de domaine local du même domaine Comptes, groupes globaux et groupes universels d'autres forêts et de domaines externes	Peut être converti en étendue universelle si le groupe ne contient aucun autre groupe de domaine local	Dans le même domaine	Autres groupes de domaine local du même domaine Groupes locaux sur des ordinateurs du même domaine, à l'exclusion des groupes intégrés qui ont de

Groupes à privilèges

- **Dans un domaine Active Directory, différents groupes de sécurité sont identifiés comme étant à privilèges :**
    - **Account Operators**
    - **Administrators**
    - **Backup Operators**
    - **Domain Admins**
    - **Domain Controllers**
    - **Enterprise Admins**
    - **Print Operators**
    - **Read-only Domain Controllers**
    - **Replicator**
    - **Schema Admins**
    - **Server Operators**

Groupes à privilèges – Mécanisme du adminCount

- **Dans le but de tracer les comptes ayant eu un « privilège élevé », et afin de prémunir certaines actions de prise de contrôle de l'AD, un mécanisme dans l'AD (SDPROP pour Security Descriptor Propagator), éxécuté toutes les heures sur le PDC, réalise les opérations suivantes :**
  - **Mise à jour de la propriété AdminCount à 1 sur l'objet AD**
  - **Copie de l'ACL portée sur l'objet AdminSDHolder sur l'objet**

- **Un attribut, le dSHeuristic, défini les groupes à exclure de ce mécanisme**
  - **L'attribut est dans la partition configuration, sur l'objet CN=Directory Service,CN=Windows NT,CN=Services,CN=Configuration**
  - **Le parametre de gestion des groupes admin à exclure est porté par le 16ème caractère de cette propriété**

Groupes à privilèges – Mécanisme du adminCount

16th	Groups Excluded			
Character	Account Operators	Server Operators	Print Operators	Backup Operators
0 (or missing)				
1	X			
2		X		
3	X	X		
4			X	
5	X		X	
6		X	X	
7	X	X	X	
8				X
9	X			X
A		X		X
B	X	X		X
C			X	X
D	X		X	X
E		X	X	X
F	X	X	X	X

Groupes à privilèges – Mécanisme du adminCount

- **Exemple :**
  - **Pour exclure les opérateurs de sauvegarde :** *0000000001000008*
    - **Si l'attribut n'est pas initialisé ou également à 0, il faut mettre le 10ème caractère à 1 pour éviter le rejet de la mise de l'attribut dans le cas d'une chaîne de caractère de plus de 10 valeurs**
    - **Le reste des caractères doivent être à 0, et le 16ème à 8**

La sécurité des comptes à privilèges

- **Au-delà du mécanisme du SDProp, il est nécessaire de réaliser un ensemble de paramétrage autours des comptes à privilèges du domaines Active Directory**

- **Il est dit qu'un compte est à privilège lorsque ce dernier a la capacité de :**
  - **Réaliser des connexions à des fins d'opérations sur des serveurs**
  - **Réaliser des opérations sur le domaine**
  - **A la capacité de gérer des certificats sur le domaine**
  - **La capacité de gérer les imprimantes, les sauvegardes…**

- **Dans l'idéal, les comptes doivent être placés dans le groupe « Protected Users », réduisant la surface d'attaque sur ces derniers**
  - **Le groupe Protected Users bloque de nombreux mécanisme de sécurité « faible », tel que NTLM. Par conséquent, certains usages de services par ces comptes (partage de fichiers, accès à des applications web avec authentifications intégrées) peuvent se retrouver impacter.**

La sécurité des comptes à privilèges

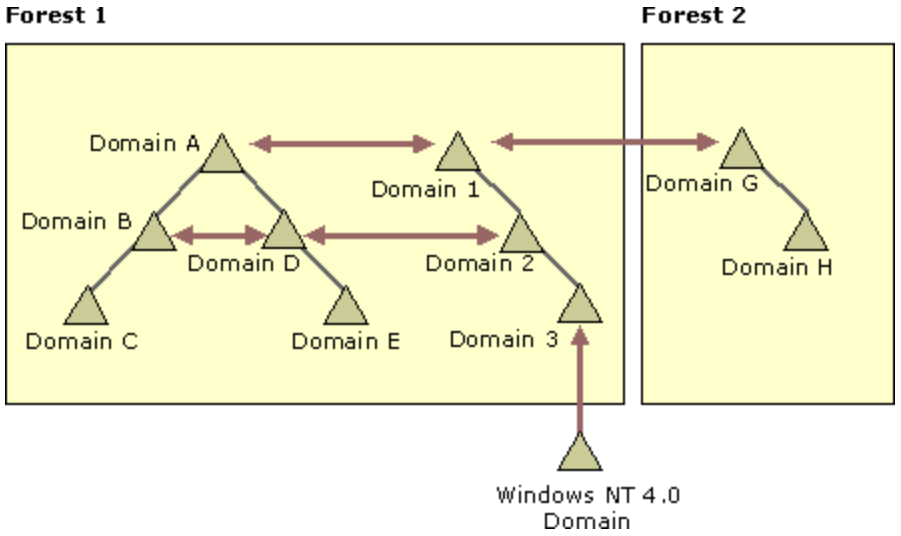
- **Il est recommandé d'appliquer la politique du moindre privilège : on ne donne QUE les droits nécessaires à l'utilisateur. L'obtention de droits supplémentaires doit être justifiée et donnée de manière temporaire.**

- **Microsoft recommande de mettre en œuvre une notion de Tiers au niveau de l'infrastructure :**
  - **Tiers 0 : les contrôleurs de domaine**
  - **Tiers 1 : les serveurs**
  - **Tiers 3 : les postes de travails**

- **Dans la notion de Tiers, un compte de Tiers inférieur (3 par exemple) ne peut intervenir sur un Tiers 0, et accéder sous certaines conditions au Tiers 1**
  - **En revanche, les comptes de Tiers 0 ne doivent JAMAIS se connecter aux Tiers 1 et 3**
  - **En effet, si la couche Tiers 1 est compromise, l'identité du Tiers 0 se retrouvera compromise et représentera une porte ouverte sur le plus haut niveau**
  - **Par conséquent, les comptes admin du domaines ne sont réservés qu'à l'administration du domaine, ni plus, ni moins.**

Relation d'approbation

- **Un trust (relation d'approbation) est une méthode permettant à une organisation Active Directory d'autoriser des ressources d'un autre domaine Active Directory**
  - **Un trust peut être bidirectionnel**
  - **Il peut être transitif, et ainsi permettre à une organisation de faire confiance à l'ensemble des domaines « trust » par une autre organisation *(dans la condition ou ces domaine seraient dans la même forêt)***



Les sites Active Directory

- **Un site Active Directory est une entitée logique représentant une localisation (par exemple un Datacenter)**
- **Un site peut regrouper plusieurs contrôleurs de domaines**
- **Un site se base sur un ensemble de configuration afin de déterminer la topologie de réplication, notamment les scopes d'adresses Ips**

- **TP : Configuration de votre premier site Active Directory**

Stratégie de groupes *(GPO – Group Policy Object)*

- **Les stratégies de groupes sont des fichiers permettant de :**
  - **Réaliser des paramétrages de sécurité, de configuration sur un ensemble de machines dans le domaine**
    - **Restriction d'ouverture de session**
    - **Restriction de lancement applicatif (Bureau à distance, interface de ligne de commande…)**
    - **Paramétrage de journalisation**
    - **Stratégie s'appliquant dans le panneau de configuration**
    - **Stratégie s'appliquant sur le registre**
  - **Réaliser des paramétrage de sécurité, de configuration sur un ensemble d'utilisateurs dans le domaine**
    - **Stratégie de répertoires (redirection de profil ou synchronisation de profil)**
    - **Stratégie permettant de bloquer les heures de connexions…**
  - **De réaliser des déploiements applicatifs, exécution de script**

- **Les stratégies sont stockées dans le SYSVOL (C:\Windows\SYSVOL\<votredomaine\Policies)**

Stratégie de groupes

- **Par défaut, les GPO s'appliquent :**
  - **toutes les 90 minutes sur les machines**
  - **Toutes les 5 minutes sur les contrôleurs de domaine**

- **L'ordre d'application d'une GPO est inversé par rapport à l'ordre de lecture dans la console des stratégies résultantes**
  - **La stratégie locale s'applique en premier (non visible dans la console, gérée localement dans une console dédiée)**
  - **La stratégie la plus éloignée de votre unité d'organisation est la première à s'appliquer au niveau de l'organisation**
  - **La dernière GPO à s'appliquer est celle située au plus proche de votre Unité d'Organisation**
  - **Il est possible de bloquer l'héritage de GPO à partir d'une OU**
  - **Les GPO forcées s'appliqueront malgré la coupure d'héritage**

Stratégie de groupes - ADMX

- **Les ADMX sont des fichiers de modèles de GPO**
  - **Des fournisseurs applicatifs tiers peuvent fournir des AMDX (Chrome, Firefox…) afin de faciliter la configuration de leurs applications à travers le domaine**
  - **Les ADMX sont stockées dans le répertoire \sysvol\domain\policies\PolicyDefinitions *(n'existe pas par défaut)***

Les rôles FSMO
Impacte de l'indisponibilité des rôles

- **Emulateur PDC**
  - **Pas de réécriture de permissions – SDHolder**
  - **Pas de synchronisation de temps, cependant, l'impact est moindre tant que les contrôleurs de domaines et les clients n'ont pas plus de 5 minutes de décalage (relativement lent à se produire)**
  - **Les stockages DFS liés aux domaines ne peuvent pas être modifiés (action réalisée via le PDC)**
  - **Pas de possibilité de réaliser une mise à niveau fonctionnel du domaine sans PDC**
  - **Les modifications de mots de passes sont mal répliquées (les changements de mot de passes réalisées sur un contrôleur de domaines sont généralement envoyées vers le PDC et vers le contrôleur de domaine le plus proche)**
    - **Avec une infrastructure AD moderne, les contrôleurs de domaines peuvent utiliser les liens intersite afin de réaliser des synchronisations entre eux. Une mise à jour de mot de passe peut donc être presque transparente**

- **Maître RID**
  - **En cas d'indisponibilité du RID, chaque contrôleurs de domaines arrivant à leur fin de pool ne pourront créées que 100 objets de sécurité**
  - **Le maître RID doit être disponible durant des migrations de domaines**

Les rôles FSMO
Impacte de l’indisponibilité des rôles

- **Maître d’infrastructure**
  - **En cas de panne, les mises à jours de sécurité entre les différents domaines ne sont pas réalisées (mise à jour des liens réalisées par des objets « fantômes »)**
  - **Si l’ensemble des contrôleurs de domaines disposent du rôle catalogue global, l’impact est réduit (seul impact : les utilisat eurs ne verront qu’un SID au lieu de voir le nom des objets membre d’un autre domaine)**

- **Maître d’attribution des noms de domaine**
  - **Impossibilité d’ajouter ou de supprimer un domaine**
  - **Impossible de modifier, ajouter ou supprimer des éléments de la partition applicative (zone DNS par exemple)**

- **Maître du schéma**
  - **Impossibilité de modifier le schéma**

Rôle FSMO – réaliser un transfert de rôle

- **La ligne de commande suivante permet de réaliser un transfert de rôle (cette commande nécessite que le serveur portant le rôle soit disponible)**
  - Move-ADDirectoryServerOperationMasterRole -Identity "USER01-DC1" –OperationMasterRole xxxx

- **En cas d'indisponibilité de ce dernier, il est possible de forcer le rôle en utilisant le commutateur « force »**

- **Cette ligne de commandes nécessite le module PowerShell Active Directory**



Les différents rôles Microsoft

Le rôle AD CS (Certification Service)

Revue générale sur les certificats

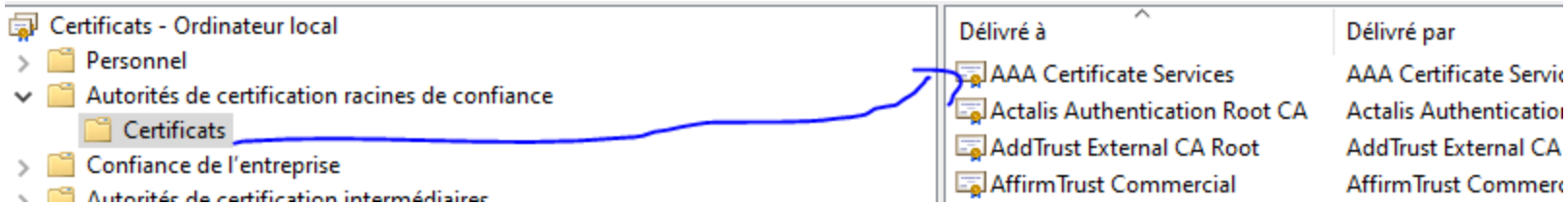
- **Les certificats est comparable à une carte d'identité électronique. Elle est composée de:**
  - **Une partie privée, permettant le chiffrement des messages envoyés par le serveur**
  - **Une partie publique, permettant aux partenaires le déchiffrement des messages**

- **Les certificats remplissent les missions suivantes :**
  - **Identifier la ressource, le partenaire avec lequel on échange**
  - **Garantir l'intégrité des données : les données étant chiffrées, il est en théorie impossible de modifier les données échangées**
  - **Garantir la confidentialité : les communications sont chiffrées entre le serveur et le client, afin de rendre non compréhensible par une personne extérieure les échanges réalisés**
  - **Non-répudiation : l'émétteur, seul dépositaire de la clef privée, ne peuvent dédier être à la source des données**

- **En règle générale, les certificats accessibles sur internet et/ou par des personnes tiers sont émis (signés) par des organismes de certification publiques**
  - **De cette manière, l'ensemble des clients reconnaissent l'identité du serveur par la validation d'un tiers de confiance**
  - **Exemple : Digicert, GlobalSign, Verisign…**

Revue générale sur les certificats

- **Sur Windows, les certificats d'autorité racine reconnue (dite de confiance) sont stockées dans le magasin local (machine) de certificats**

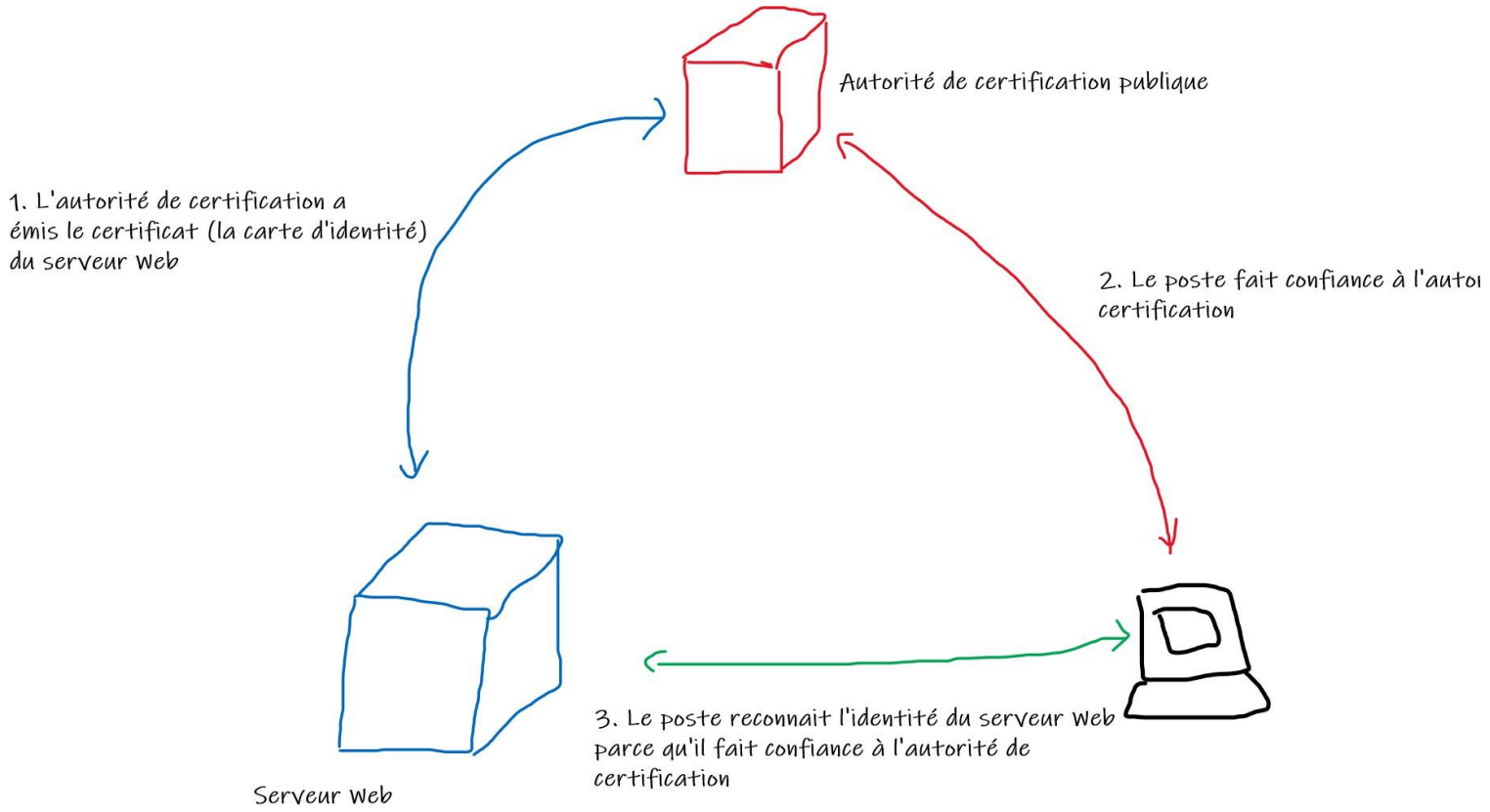


- **Dans le cas où l'utilité est uniquement de chiffrer la communication (et pas de vérifier l'identité de l'interlocuteur), l'usage d'un certificat auto-signé est suffisant.**

Les autorités de certifications
Usages & bonnes pratiques

- **Une autorité de certificat racine dispose d'une date de début *(not before)* et de fin *(not after)* de validité**
  - **L'ensemble des certificats résultant d'une autorité de certificat racine**
- **La première autorité de certification (autorité de premier niveau) est nommé autorité racine**
- **Une autorité racine n'est normalement, jamais accessible depuis le réseau**
  - **Celle doit en règle générale générée une autorité de certification secondaire, puis être déconnectée du réseau**
  - **Les clients, par la confiance accordée à l'autorité racine, font confiance aux secondaires**

Les autorités de certifications
Reconnaissance d’un poste client d’une certification



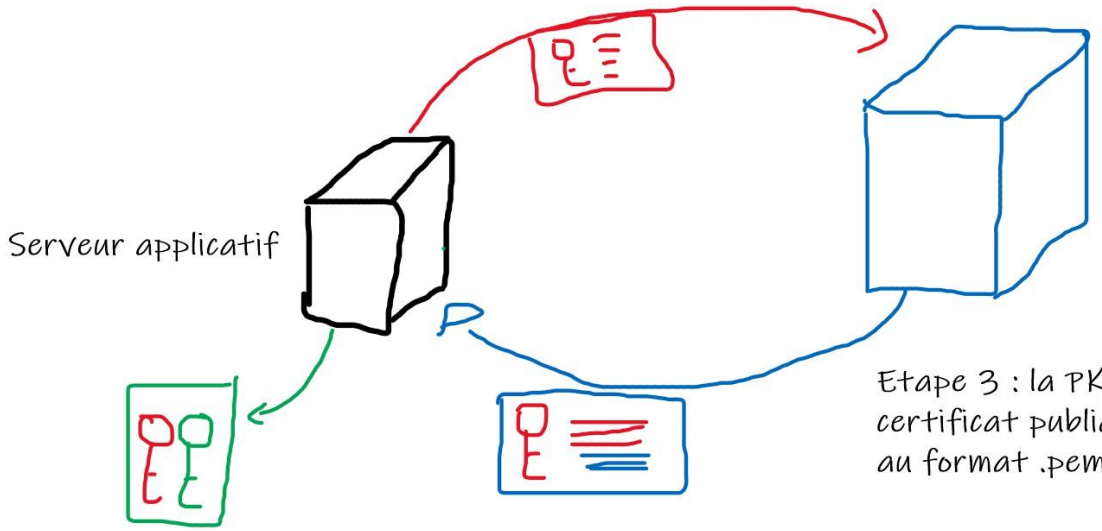
Les certificats
Usages & bonnes pratiques

- **Etape de génération d'un certificat :**
  - **Génération de la clef privée**
  - **Génération de la CSR *(Certificate Signin Request, ou demande de certificat)* en envoie auprès de l'autorité de certification**
    - **La CSR contient la clef publique ainsi que les informations relatives au certificat (not before, not after, Alternante DNS Name)**

- **Pour les usages Web, il est obligatoire d'inclure des alternatesDNSNames dans le certificat**
  - **Dans le cas contraire, le service web ne sera pas reconnu comme fiable par les différents serveurs web réalisant des appels auprès de ce dernier**

Les certificats
Schéma de principe de génération d'un certificat

Etape 2 : le serveur génère une CSR
La CSR contient la clef publique ainsi que les informations d'identifications (CN, Alternates Names...)



Etape 3 : la PKI valide la CSR et fourni le certificat publique (généralement dans archive au format .pem)

Etape 1 : le serveur Web génère une clef privée et une clef publique

La clef privée est stockée localement et est utilisée par le serveur pour chiffrer les communication ultérieurements

Le rôle AD CS de Windows Server

- **Le rôle AD CS (Active Directory – Certificate Service) est le service de Microsoft permettant de mettre en œuvre une infrastructure de certificat**

- **Le rôle AD CS réponds principalement aux besoins suivants :**
  - **Mise en œuvre d'une autorité de certificat au sein d'une infrastructure privée**
  - **Autorité de certification - Enrôlement web : permet la demande de certificat à l'aide d'une interface web (interaction utilisateur)**
  - **Certificate Enrollment Policy Web Service : service permettant de délivrer un certificat par l'intermédiaire du protocole HTTPS sans interaction utilisateur**
    - **Ce mécanisme permet de répondre à des usages d'enrôlement, de renouvellement pour des postes non joins au domaine ou en dehors du réseau interne**
  - **Répondeur en ligne : fournis le mécanisme de CRL (Certificate Révocation List : liste des certificats révoqués par l'infrastructure)**
  - **Enrôlement d'appareils réseaux (switchs, routeurs…)**

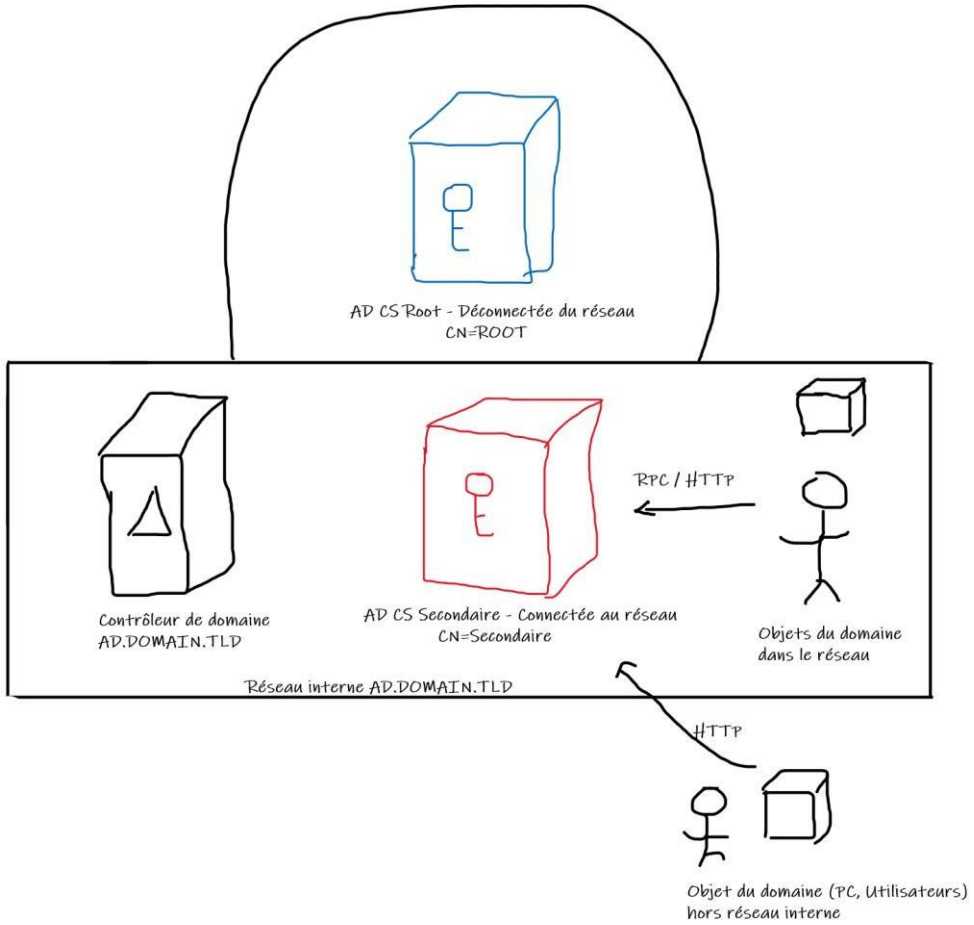
AD CS – Bonnes pratiques supplémentaires

- **Contrôler au maximum les règles firewall entre le serveur AD CS et les clients**
  - **Protocoles néccessaires : HTTPS, RPC**
- **Désactiver l'usage de LM et NTLMv1**
- **Le serveur AD CS ne doit pas être mutualisé avec d'autres rôles**
- **Réaliser des sauvegardes régulières**
- **Désactiver l'usage du MSTSC et WinRM**
- **Contrôler les accès sur la machine**

AD CS – Les différents rôles administrateurs

- **CA Administrateur (les Domain Admins sont membre du CA Administrateur)**
  - **Gère l'autorité et peut générer/révoquer des certificats**
- **Gestionnaire de certificat : peut révoquer et générer des certificats**
- **Enrôlement : autorise la demande de certificat**
- **Opérateur de sauvegarde : peut réaliser des sauvegardes**
- **Auditeur : accède aux journaux d'audit et de sécurités**

AD CS – Principe d’architecture générale



LAB 1 – Installation du rôle AD CS

- **Lancez PowerShell en tant qu'Administrateur sur un serveur Windows**

- **Exécutez la ligne de commande suivante :**

  Install-AdcsCertificationAuthority -CAType StandaloneRootCa

  - **Cette ligne de commande permet de réaliser une installation du rôle AD CS avec les paramètres par défaut**
  - **Il est possible de préciser un ensemble de paramètre :**
    - **L'algorythme**
    - **La période de validité**
    - **La longueur de la clef privée…**

- **Si vous le souhaitez, vous pouvez ajouter également (sur un autre serveur) une autorité secondaire (en dessous de votre autorité de certification root)**
  - Install-AdcsCertificationAuthority -CAType EnterpriseSubordinateCa -ParentCASERVERADCSROOT.AD.DOMAIN.TLD\SERVERADCSROOT-CA
  - **Dans ce cas, une fois la deuxième autorité déployée, vous pouvez arrêter le serveur précédent**

LAB 1 – Installation du rôle AD CS

- **Lancez PowerShell en tant qu'Administrateur sur un serveur Windows**

- **Exécutez la ligne de commande suivante :**

  Install-AdcsCertificationAuthority -CAType StandaloneRootCa

  - **Cette ligne de commande permet de réaliser une installation du rôle AD CS avec les paramètres par défaut**
  - **Il est possible de préciser un ensemble de paramètre :**
    - **L'algorythme**
    - **La période de validité**
    - **La longueur de la clef privée…**

- **Si vous le souhaitez, vous pouvez ajouter également (sur un autre serveur) une autorité secondaire (en dessous de votre autorité de certification root)**
  - Install-AdcsCertificationAuthority -CAType EnterpriseSubordinateCa -ParentCASERVERADCSROOT.AD.DOMAIN.TLD\SERVERADCSROOT-CA
  - **Dans ce cas, une fois la deuxième autorité déployée, vous pouvez arrêter le serveur précédent**

LAB 2 – Publication d'un modèle de certificat

Dans ce LAB, vous allez réaliser la publication d'un modèle de certificat Web

- **Dans le menu démarrer, recherchez la console de l'Autorité de Certification (Certificate Authority)**
- **Cliquez droits sur « modèles de certificat (Certificate Template) » et cliquez sur Gérer (Manage)**
- **Une nouvelle console doit s'ouvrir, recherchez le modèle de certificat web, et cliquez droit sur ce dernier, et cliquez sur propriété**
- **Recherchez l'onglet sécurité, et ajoutez le groupe « Ordinateurs du domaine / Domain Computers »**
  - **Donnez les autorisations lectures, enrôlement et écriture**
  - **Validez et fermez les propriétés du template ainsi que le gestionnaire des modèles**

- **Dans la console de l'autorité de certification, dans Modèles de certificats, dans le menu « Action », cliquez sur « Nouveau », puis sur « modèle de certificat à délivrer».**
  - **Sélectionnez le modèle de certificat Web et validez**



Les différents rôles Microsoft

Le rôle AD FS (Federation Service)

Présentation générales de l'AD FS

- **L'AD FS (Active Directory – Federation Service) est le service Microsoft permettant de centraliser l'authentification des applications (externes ou internes)**

- **Chaque application dispose de son propre référentiel d'utilisateur, généralement synchronisé avec Active Directory à l'aide de requêtes LDAP**

- **Auparavant, chaque application gérait son authentification**
  - **L'utilisateur devait alors s'authentifier sur chacune des applications**

- **L'ADFS permet de déléguer l'authentification à un service unique, amenant ainsi au SSO *(Single Sign-On)***